The agent permission ladder

Give your AI agent hands, safely. Start at level 1 and let it earn every level. You're not late: you're right on time.

1 · THE LEVELS (AFTER THE CLOUD SECURITY ALLIANCE)

LEVEL	WHAT THE AGENT DOES	YOUR CONTROLS	RISK
0 Advisor	Reads and suggests. You do everything.	Read-only access	
1 Assistant	Does the work; every action waits for your OK.	Approve button on every action	
2 Supervised	You approve a plan; it executes inside it.	Plan approval, pause, cancel, roll back	
3 Conditional	Acts alone inside boundaries; asks outside them.	Budgets, allow lists, escalation, logs	
4 High autonomy	Broad freedom; you watch for anomalies.	Monitoring, alerts, a real kill switch	
5 Full autonomy	Sets its own goals.	Not for business use today	

2 · WHICH LEVEL FOR WHICH JOB

Reading and summarizing (news, documents, inbox)	**Level 0-1**
Drafting emails, posts, replies (you press send)	**Level 1**
Updating your CRM or calendar, once you trust the plan	**Level 2**
Payments, refunds, deleting anything	**Level 1, forever**

3 · THREE CONTROLS BEFORE YOU GIVE ANY AGENT HANDS

- [ ] **Least privilege.** Each job gets only the access it needs. Read-only unless there is a reason. One token per task, never one token for everything.
- [ ] **A human approve button** in front of anything you cannot undo: deleting, sending, paying, publishing.
- [ ] **A kill switch and a spending cap.** One click stops everything; every run has a hard cost limit. Keep backups where the agent cannot reach them.

4 · ADD IT TO THE FREE AGENT (GITHUB, ABOUT 3 MINUTES)

- [ ] Update your copy of **github.com/pavelpravosud/ai-morning-briefing** to v2 (new workflow, publish.py, cost cap).
- [ ] **Settings** → **Environments** → **New environment** `publish` → **Required reviewers** = you → **Save protection rules**. (Works on public repos on every plan.)
- [ ] Kill switch: **Settings** → **Secrets and variables** → **Actions** → **Variables** `AGENT_ENABLED` = `false`. Spending cap: variable `MAX_COST_USD` (default 0.05).
- [ ] Run it: **Actions** → **AI Morning Briefing** → **Run workflow**, read the draft issue, then **Review deployments** → **Approve**.

Why this matters: in April 2026 an AI coding agent wiped a company's production database and its backups in seconds with one over-powered API token and no approval step (reported by Epic IT, 13 Jun 2026).

From "Give your AI agent hands. Safely." · The AI Person Masterclass, lesson 2 · Facts as of 6 Nov 2026 · Sources: Cloud Security Alliance (Levels of Autonomy, Jan 2026), Epic IT, CrowdStrike, DigitalOcean

© 2026 Pavel Pravosud